

[doc. web n. 10037439]
Provision of May 23, 2024
Register of provisions
No. 306 of May 23, 2024

THE GUARANTOR FOR THE PROTECTION OF PERSONAL DATA

IN the meeting held today, attended by
Prof. Pasquale Stazione, President, Prof.
Ginevra Cerrina Feroni, Vice President, Dr.
Agostino Ghiglia, and Attorney Guido Scorza, members, and
Secretary General Fabio Mattei;

HAVING REGARD TO Regulation (EU) 2016/679 of the European Parliament
and of the Council, of April 27, 2016, on the protection of natural persons with respect to the
processing of personal data, as well as the free movement of such data and repealing Directive
95/46/EC, "General Data Protection Regulation" (hereinafter "Regulation");

HAVING REGARD TO Legislative Decree No. 196 of June 30, 2003, containing the "Code regarding
the protection of personal data, containing provisions for the adaptation of the national legal system to
Regulation (EU) 2016/679 of the European Parliament and of the Council, of April 27, 2016, on the
protection of natural persons with respect to the processing of personal data, as well as the free
movement of such data and repealing Directive 95/46/EC" (hereinafter "Code");

HAVING REGARD TO Legislative Decree No. 101 of August 10, 2018, containing "Provisions for the
adaptation of national legislation to the provisions of Regulation (EU) 2016/679 of the European
Parliament and of the Council, of April 27, 2016, on the protection of natural persons with respect to
the processing of personal data, as well as the free movement of such data and repealing Directive
95/46/EC";

HAVING REGARD TO Regulation No. 1/2019 concerning internal procedures with external relevance,
aimed at carrying out the tasks and exercising the powers entrusted to the Guarantor for the protection
of personal data, approved by resolution No. 98 of April 4, 2019, published in G.U. No. 106 of May 8,
2019 and on www.gpdp.it, doc. web No. 9107633 (hereinafter "Guarantor Regulation No. 1/2019");

HAVING REGARD TO the documentation on file;

HAVING REGARD TO the observations made by the Secretary General pursuant to Article 15 of the
Guarantor Regulation No. 1/2000 on the organization and functioning of the office of the Guarantor for
the protection of personal data, doc. web No. 1098801;
Reporter Prof. Pasquale Stazione;

PREMISED

1. Notification of data breach

With notes dated XX and XX, the Local Health Authority TO4, hereinafter "Authority," notified a
personal data breach, pursuant to Article 33 of the Regulation, stating, in particular, that "on XX at
14:04, the interested party (...) submitted via email to the URP (...) a detailed complaint in which she
stated that she had received on XX, at 10:32, from the neurology clinic's secretariat an email (from the
address ambulatoriosm.cirie@aslto4.piemonte.it) with the subject 'methods for renewing the
therapeutic plan,' sent to another 44 email addresses in clear text and, after about half an hour, a
second email correcting the first with the same modalities. She complained of a violation of her
personal privacy. The URP, with an internal note via email at 14:35, communicated the complaint to
the director of the Neurology SC and to the medical director of the Ciriè-Lanzo hospital facility. On
15/7, the Neurology SC, with a note signed by the director, communicated to the facility management
the outcome of the first internal investigation, which revealed that the event occurred due to human
error by the secretary, who, mistakenly disregarding the instructions on data processing for the
purpose of sending communications, transmitted a circular of instructions on the therapeutic plan

(lacking specific indications) to 45 addresses of patients affected by multiple sclerosis, inserting the respective addresses in the CC field in clear text. Subsequently, on XX, at 16:24, the medical director of the Ciriè Lanzo facility sent the company privacy office the documentation related to the episode, attaching the complaint and the two communications sent by the clinic. The privacy office, as soon as the investigation was completed, proceeded with the preliminary communication to the Guarantor Authority."

In the aforementioned notes, the Authority indicated, as technical and organizational measures present at the time of the breach, adopted to ensure the security of the personal data involved, the "operational instructions on the use of electronic mail" and the "specific instructions on the processing of health data, present in the letter of authorization for data processing."

According to what was communicated by the Authority, the data subject to breach involved "45 email addresses and, partially, about 45 personal references related to the holders of such addresses; the nature of the communication allows inferring the status of a patient affected by multiple sclerosis and/or demyelinating diseases."

The Authority also stated that, following the breach, a "verbal warning was issued to the operator who incorrectly sent the email" and that the technical and organizational measures adopted (or proposed for adoption) included "1 - Specific training for URP staff as the point of reception for communications/complaints from users; 2 - Specific training for the staff of the Neurology SC as the unit affected by the DB; 3 - Renewal of operational instructions for URP staff for internal communications (assignment by competence); 4 - Renewal of specific instructions on the use of electronic mail for internal staff. 5 -

Update of the manual on the use of IT tools."

2. Assessments of the Department on the processing carried out and notification of the violation referred to in Article 166, paragraph 5 of the Code

In relation to the facts described in the notification of violation, the Office, with note of XX (prot. n. XX), notified the Company, pursuant to Article 166, paragraph 5, of the Code, of the initiation of proceedings for the adoption of measures referred to in Article 58, paragraph 2, of the Regulation, inviting it to submit defensive writings or documents to the Authority or to request to be heard by the Authority (Article 166, paragraphs 6 and 7, of the Code; as well as Article 18, paragraph 1, of Law No. 689 of 24/11/1981). This was because it was deemed that the Company had communicated personal data and health data of 44 patients to the same number of patients, in the absence of a suitable legal basis and, therefore, in violation of the basic principles of processing referred to in Articles 5, 6, and 9 of the Regulation and Article 2-ter of the Code.

With note of XX, the Company submitted its defensive memoranda, in which it highlighted, in particular, that:

- "the processing involved in the violation concerns the transmission of correspondence in support of the Company's diagnostic and care activities; this processing is included in the processing of health data (i.e. data capable of revealing the health status of the data subject) (...);"
- "this processing occurs on the legal basis of the combined provisions of the following norms: Article 9, paragraph 2 letters "g", "h" and "i" of EU Regulation No. 2016/679 ("GDPR"); Article 2-sexies, paragraph 2, letters t, u, v, cc, Legislative Decree 196/2003 and subsequent amendments (reasons of significant public interest related to the specific case) (...);"
- "the purpose of the data processing in question is therefore that of diagnosis, assistance, and healthcare therapy for the interested patient and, related to it, administrative activities related to specialized outpatient care (...);"
- "for the performance of the administrative activity in question, consisting of handling correspondence via email, aimed at correctly informing the neurological patient about the progress of care activities, the Company has provided training and information to the operators, and this despite the fact that the correct use of email should be considered, in the current historical context, common knowledge among people with average education, similar to all other tools for conducting correspondence";
- "the events reported in the notification of violation that initiated the proceedings stem from the failure

to apply, by the designated personnel, due to simple oversight, the precautions normally used for written communication. In fact, human error in the application of the procedure did interfere with the communication activity, but it certainly did not constitute its purpose”;

- “the event was of an absolutely accidental nature. The use of email constitutes (...) a normal procedure aimed at communication with the patients of the Neurology Department. Such sending is, as a rule, individual or - in the case of collective sends - characterized by the use of the “blind carbon copy” (BCC) mode in order to avoid communications to incorrect recipients. The reason for the choice made in favor of email as a means of communication is dictated on the one hand by the widespread use of this tool, and on the other hand by the fact that this means, being essentially qualified as “postal”, is supported by the guarantees provided by current legislation”;

- “regarding the severity of the violation, (...), while noting that the events in question have a high theoretical risk, the impact, measured on Table 1 of the ENISA WP2017 0-2-2-5 (severity table based on potential consequences for the data subject), related to the specific case has highlighted that in fact the data subjects appear to have suffered consequences compatible with the “medium” severity of the event (“Individuals may encounter significant inconveniences, which they may overcome with some difficulty (extra costs, denial of access to professional services, fears, misunderstandings, stress, minor physical inconveniences, etc.”), reasonably attributable to the categories of “fears” and “stress””;

- “such effects are also confirmed by the subsequent attitude of the complainant, who through her lawyer has complained of fears regarding the knowledge of the pathological state by third parties, knowledge that is partially likely to lead to changes in the attitude of these towards the complainant herself”;

- “the continuation of correspondence with her lawyer has reiterated this circumstance, as even after some time no further allegations regarding potential damage have emerged, limiting itself to reiterating the presence of “frustration and psycho-emotional disturbance”, all manifestations (aside from any objective evidence that has not been provided so far) compatible with the (aforementioned) etiological classification (...);”

- “the number of data subjects involved in the violation is 44. The violation had an overall limited duration; in fact, it is noted that the two sends occurred just a few minutes apart, so much so that both can be considered as resulting from the same human error”;

- “the violation was of a negligent nature. The conduct appears to have been accidental, as admitted by the same operator involved during the disciplinary proceedings.”

- “This Administration has promptly notified the interested parties of the event as soon as it became aware of it. The event itself (incorrect clear communication of a list of addresses related to information about the status of a recipient of a therapeutic plan) is not susceptible to mitigation in its effects, except through the communication of the event itself to the interested parties, in accordance with the provisions of Article 34 GDPR.”;

- “The processing subject to the violation is characterized by a potential risk level estimated as 'high', as highlighted in the relevant processing sheet; it is, however, carried out entirely by personnel employed by the Company, who are nonetheless required to comply with the Code of Conduct referred to in Article 54 of Legislative Decree No. 165 of March 30, 2001, which the Company has adopted with resolution No. 907 of 2018 (...), now updated with resolution No. 920 of October 21, 2022; this act, in Article 12, paragraph 6, clearly delineates the employee's obligation of confidentiality under Article 2105 of the Civil Code as an obligation to observe official secrecy and the regulations on the processing of personal data, actively working to avoid disclosing information related to official activities, and therefore also personal data of any category that they become responsible for. The administrative personnel assigned to the Neurology Department (...) through the Hospital Medical Management of Ciriè, has also received training on the processing of personal data (...);”

- “The processing in question is also supported by the procedure referred to in (...) the Company Regulation for the Use of IT Systems – resolution 3/07/2020 No. 713, (...). This document was under revision at the time of the data breach event for which proceedings are being initiated; however, even in the current edition, in paragraph 8, 'use of email', it is stipulated that 'Where it is necessary to send a document containing sensitive data, the creation of a password-protected file is mandatory (in the case

of multiple documents, create a compressed folder always protected by a password). The password must be communicated through another means (e.g., SMS, dictated over the phone, etc.);"

- "Following the event in question, the Company has implemented the following additional organizational measures: a. Renewal of specific instructions on the use of email for internal staff; b. Specific training for the URP staff as the point of reception for communications/complaints from users; c. Specific training for the staff of the Neurology Department of Ciriè as the unit affected by the event; d. Renewal of operational instructions for URP staff for internal communications (assignment by competence); e. Update of the manual for the use of IT tools;"

- "In particular, the 'manual for the use of IT tools', (...), currently under approval, now includes the following specific instruction: 'The uncontrolled dissemination of systems to propagate messages to a widespread and multiplied audience that induces the recipient to produce multiple copies to send, in turn, to new recipients, should be avoided, as it limits the efficiency of the mail system. The use of the recipient 'BCC' (Blind Carbon Copy) is encouraged whenever it is necessary to privately inform a certain number of recipients about the contents of the email, preventing all from seeing the other recipients; this practice is preferred in communications where the same content must be sent to multiple recipients without the other recipients being aware of it. In this case, the recipient in BCC at the time of the reply will not send to all recipients but only to the sender';"

- "Since this is largely a manual operation, therefore dependent exclusively on the skill and diligence of the operator in carrying out their duties, the Company has initiated a disciplinary procedure against the author of the error, which concluded with the imposition of a labor law sanction (...);"

- "The Administration is also exploring the technical possibility of implementing a technical procedure in its email/antispam system that facilitates the interception of multiple sends in order to reduce human risk;"

- "OMISSIS;"

- "The communication of data such as the status of a recipient of a therapeutic plan is understood as communication only in the circumstance where such communication occurs for (...) the purpose identified by the Data Controller, and in this context is subject to specific procedures, designations, instructions, and specific training of the individuals appointed pursuant to Article 29 GDPR;"

- "The operation of communication found its definition, in the previous regime, in the repealed Article 4, paragraph 1, letter I, of Legislative Decree No. 196/2003 (...). Currently, this definitional norm has lapsed, but the notion of communication has fallen within the processing operations referred to in Article 4, No. 2 GDPR, as it is understood precisely as a processing operation, therefore as an activity carried out consciously by the controller for a purpose. This distinction is essential to differentiate communication as a processing operation (i.e., communication carried out with a purposeful logic by the Data Controller, who processes the data for a purpose - even regardless of the legality of this) from disclosure outside the provisions of the information and the relevant regulations. And indeed, this latter event constitutes a violation of confidentiality (...), but it is still an event that did not fall within the purpose of..."

****Processing**.**

The Health Authority has made considerations regarding the qualification of the violation, considering it to be an unexpected and accidental disclosure of health-related data resulting in a breach of confidentiality that did not fall within the purpose of processing. The data controller also highlighted that they believe "an accidental breach of confidentiality" cannot "be requalified as a processing operation (sub species, communication) lacking a legal basis; indeed, such an assessment would entail a premature judgment regarding the existence of a processing purpose (which does not exist) not supported by an appropriate legal basis, which would imply that it is possible to attribute to the offender a behavior in the absence of awareness and intent, or in the presence of a fact that interrupts the causal link (which is excluded pursuant to Article 3 of Law 689/81)", emphasizing, in any case, that "the breach in question was promptly reported by this Administration pursuant to Articles 33 and 34 of the GDPR; that measures have been introduced that are deemed suitable to further reduce the risk of

a recurrence of the event in the future, that the breach involved only a set of email addresses, and that only one of the data subjects has complained of effects, which are, moreover, apparently limited."

In the hearing held on XX, it was also stated that:

- "regarding the measures adopted following the breach, the current email service provider was asked about the possibility of implementing an 'alert' that notifies the user that they are sending an email to individuals outside the organization, in order to intercept any improper use of the 'cc' field. Evidence of this request and the related response was provided through the transmission, on XX, to the Authority of a copy of the correspondence exchanged (...).

The Company declares its commitment to replicate the same request to the new email service provider that will be identified during the next year, following a selection process";

- "a draft of a new regulation for the use of IT tools by the Company's employees is currently under review by the trade unions, which contains the specifications indicated in the memorandum for the use of the recipient in 'cc'; this regulation may be refined and updated in view of the upcoming change of provider";

- "an update of training has been planned, also regarding the critical profiles that led to the event, with particular reference to the use of email, company devices, and the Internet."

****3. Outcome of the Investigative Activity****

Taking note of what has been represented by the Company in the documentation on file, in the defense memoranda, it is observed that:

1. email addresses fall under the notion of personal data, even if devoid of references to the name and surname or otherwise to other directly identifying information of the data subjects; the circumstance that, from the context of the communication, it could be inferred that the recipients of the emails, sent by the neurology clinic's secretariat and concerning the "renewal of the therapeutic plan", were patients being treated at the aforementioned clinic, has resulted in the described processing involving health data, as it concerns information related to healthcare services, which reveal information about health status (Article 4, paragraph 1, no. 15 of the Regulation; see, among others, the provision of June 25, 2002, web doc no. 29864, provision of January 9, 2020, web doc 9261234, provision of June 24, 2003, web doc no. 1132562);

such data merit greater protection since the context of their processing could create significant risks for fundamental rights and freedoms (Cons. no. 51);

2. the Code, in the version reformulated by Legislative Decree no. 101/2018, defines the communication of personal data, understood as "the disclosure of personal data to one or more specific subjects other than the data subject, the representative of the data controller in the territory of the European Union, the processor or their representative in the territory of the European Union, and the persons authorized, pursuant to Article 2-quaterdecies, to process personal data under the direct authority of the controller or the processor, in any form, including by making them available, consulting, or through interconnection" (Article 2-ter, paragraph 4, letter a);

3. the regulations regarding the protection of personal data provide - in the health sector - that information about health status can only be communicated to the data subject and can be communicated to third parties only on the basis of an appropriate legal basis (Article 9 of the Regulation and Article 84 of the Code in conjunction with Article 22, paragraph 11, Legislative Decree of August 10, 2018, no. 101);

4. the data controller is required to comply with the principles regarding data protection, among which is the principle of "integrity and confidentiality", according to which personal data must be "processed in a manner that ensures adequate security (...), including protection, through appropriate technical and organizational measures, against unauthorized or unlawful processing and against accidental loss, destruction, or damage" (Article 5, paragraph 1, letter f) of the Regulation).

In light of the evaluations mentioned above, taking into account the statements made by the data controller during the investigation - and considering that, unless the fact constitutes a more serious offense...

****Criminal Offense****

Anyone who, in a proceeding before the Authority, falsely declares or certifies news or circumstances

or produces false acts or documents is liable under Article 168 of the Code "Falsehood in declarations to the Authority and interruption of the execution of the tasks or exercise of the powers of the Authority." It is represented that the elements provided by the Company in the notification of violation, in the defensive memoranda, and during the hearing do not allow for overcoming the objections notified by the Office with the aforementioned initiation act of the proceeding, nor do any of the cases provided for by Article 11 of the Authority's Regulation No. 1/2019 apply.

As described above, the sending of the two communications, transmitted approximately half an hour apart from each other, originating from the neurology office's secretariat and concerning the "methods for renewing the therapeutic plan," occurred through a single email message addressed to multiple recipients, whose addresses were clearly included in the carbon copy (c.c.) field; this circumstance has, in fact, without justified reason and in the absence of a legal basis, mutually revealed to the recipients of the same communications the health status of other patients, giving rise to a communication of health data concerning the interested parties (to whom the email addresses pertain), in violation of the basic principles set forth in Articles 5, paragraph 1, letter f), and 9 of the Regulation.

On this point, the arguments put forth by the data controller are not sufficient to exclude their liability in relation to the contested matter, since, regarding the error in which the authorized person who carried out the processing operations in question would have incurred twice, there is no condition that allows us to assert that the error was unavoidable and blameless, such that it could have been avoided with ordinary diligence.

In light of the established case law of the Supreme Court (Cass. No. 7885/2011, Cass. No. 16320/2010, Cass. No. 19759/2015, Cass. No. 33441/2019, and Cass. No. 17822/2021), for the purposes of applying the invoked Article 3 of Law No. 689/1981, it is necessary that good faith or error is based on a positive element, foreign to the agent and capable of determining in them the conviction of the lawfulness of their behavior (excusable error). This positive element must be such that it cannot be avoided by the agent with the use of ordinary diligence. In this case, the operator could have diligently verified, through more accurate control, the correctness of the operations carried out during the sending of the emails, thereby avoiding the communication of health data to unauthorized third parties.

For these reasons, the unlawfulness of the processing of personal data carried out by the Company is noted, as stated in the reasoning. In this context, considering, in any case, that the conduct has exhausted its effects and that the Company has expressed the intention to implement technical and organizational measures deemed necessary to prevent future similar occurrences and, in any case, to minimize human error, the prerequisites for the adoption of measures, of a prescriptive or prohibitory nature, under Article 58, paragraph 2, of the Regulation do not exist.

****4.** Adoption of the injunction order for the application of the administrative pecuniary sanction and accessory sanctions (Articles 58, paragraph 2, letter i) and 83 of the Regulation; Article 166, paragraph 7, of the Code). **

The violation of Articles 5, paragraph 1, letter f) and 9 of the Regulation is subject to the application of the administrative pecuniary sanction pursuant to Article 83, paragraph 5 of the Regulation.

It should be noted that the Authority, pursuant to Articles 58, paragraph 2, letter i) and 83 of the Regulation, as well as Article 166 of the Code, has the power to "impose an administrative pecuniary sanction pursuant to Article 83, in addition to [other] corrective measures [provided for in this paragraph], or in lieu of such measures, depending on the circumstances of each individual case," and, in this context, "the Board [of the Authority] adopts the injunction order, which also provides for the application of the accessory administrative sanction of its publication, in whole or in part, on the Authority's website pursuant to Article 166, paragraph 7, of the Code" (Article 16, paragraph 1, of the Authority's Regulation No. 1/2019).

The aforementioned administrative pecuniary sanction imposed, depending on the circumstances of each individual case, must be determined in amount taking into account the principles of effectiveness, proportionality, and deterrence, as indicated in Article 83, paragraph 1, of the Regulation, based on the

elements provided for in Article 83, paragraph 2, of the Regulation.

In light of the above and, in particular, of the category of personal data involved in the violation, the number of affected subjects (44), and the unintentional nature of the violation, it is believed that the level of severity of the violation committed by the Company is medium (cf. European Data Protection Board, "Guidelines 04/2022 on the calculation of administrative fines under the GDPR" of May 23, 2023, point 60).

It is also noted that the Company has already been the recipient of a measure adopted pursuant to Article 58 of the Regulation, which, however, concerned the activation of video surveillance systems in violation of Article 4 of Law No. 300 of May 20, 1970 (cf. provision of March 5, 2020, No. 53, web document No. 9433080). Therefore, the aforementioned violation cannot be classified as a "previous relevant violation" pursuant to Article 83, paragraph 2, letter e) of the Regulation.

Here is the translated text:

Having established the above, and having evaluated certain elements as a whole, in particular that:

- the Authority became aware of the event following the notification of a breach made by the Company, pursuant to Article 33 of the Regulation, as soon as it received a report in this regard (Article 83, paragraph 2, letter h) of the Regulation);
- the data controller, in order to prevent the recurrence of the event that occurred, committed to implementing training activities for authorized operators handling personal data and designing "alert" procedures for the use of the "c.c." field in emails (Article 83, paragraph 2, letters c) and f) of the Regulation);
- the breach concerned a specific internal structure of the data controller and not its overall organization and was caused by an error of an operator, who is nonetheless subject to disciplinary proceedings (Article 83, paragraph 2, letter k) of the Regulation).

It is deemed appropriate to determine the amount of the administrative fine provided for by Article 83, paragraph 5 of the Regulation, in the amount of €8,400.00 (eight thousand four hundred) for the violation of Articles 5 and 9 of the same Regulation, as an administrative pecuniary sanction deemed, pursuant to Article 83, paragraph 1, of the Regulation, effective, proportionate, and dissuasive.

It is also considered that the accessory sanction of publication on the Authority's website of this provision should be applied, as provided for by Article 166, paragraph 7 of the Code and Article 16 of the Authority's Regulation No. 1/2019, also in consideration of the type of personal data subject to unlawful processing.

Finally, it is noted that the conditions referred to in Article 17 of Regulation No. 1/2019 concerning internal procedures with external relevance, aimed at carrying out the tasks and exercising the powers delegated to the Authority, are met.

HAVING SAID THAT, THE AUTHORITY

declares the unlawfulness of the processing of personal data carried out by the Local Health Authority TO4, for the violation of the fundamental principles of processing, as set out in Articles 5 and 9 of the Regulation, as stated in the reasoning;

ORDERS

pursuant to Articles 58, paragraph 2, letter i) and 83 of the Regulation, the Local Health Authority TO4, with legal headquarters at Via Po No. 11 - 10034 Chivasso (TO), C.F./P.IVA No. 09736160012, to pay the sum of €8,400.00 (eight thousand four hundred) as an administrative pecuniary sanction for the violation indicated in this provision; it is represented that the offender, pursuant to Article 166, paragraph 8, of the Code, has the option to settle the dispute by payment, within 30 days, of an amount equal to half of the imposed sanction;

ENJOINS

the aforementioned Company, in the event of failure to settle the dispute pursuant to Article 166, paragraph 8, of the Code, to pay the sum of €8,400.00 (eight thousand four hundred) according to the methods indicated in the annex, within 30 days from the notification of this provision, under penalty of the adoption of subsequent enforcement actions in accordance with Article 27 of Law No. 689/1981;

DISPOSES

pursuant to Article 166, paragraph 7, of the Code, the full publication of this provision on the Authority's website and considers that the conditions referred to in Article 17 of Regulation No. 1/2019 concerning internal procedures with external relevance, aimed at carrying out the tasks and exercising the powers delegated to the Authority, are met.

Pursuant to Article 78 of the Regulation, Articles 152 of the Code, and Article 10 of Legislative Decree No. 150/2011, against this provision it is possible to appeal before the ordinary judicial authority, under penalty of inadmissibility, within thirty days from the date of communication of the provision itself or within sixty days if the appellant resides abroad.

Rome, May 23, 2024

THE PRESIDENT

Stanzione

THE RAPPORTEUR

Stanzione

THE SECRETARY GENERAL

Mattei